

Discharged Secrets: Lifecycle Telemetry and Supply-Chain Exposure in Serviced Hardware for Critical Infrastructure

Anonymized manuscript

Abstract

Critical-infrastructure organizations increasingly use connected devices that they do not own, maintain, or decommission. Shared micromobility provides a visible example of this broader class of serviced hardware. Existing assessments often concentrate on real-time location, yet exposure can persist when positioning is disabled because battery consumption, odometry, fault events, and service records may reveal identity, occupancy, operating tempo, and recurring activity. This article presents a structured evidence synthesis spanning mobility re-identification, micromobility privacy measurement, battery side channels, battery-management data, connected-vehicle governance, and cybersecurity supply-chain guidance. It develops a lifecycle model covering procurement, deployment, operation, maintenance, recall or return, and second-life disposal. The model shows that risk depends not only on connectivity but also on custody, data retention, component provenance, contractor access, and the legal jurisdiction of service backends. A Japanese government-facility deployment is used as a bounded policy vignette; no compromise or vendor misconduct is alleged. The article proposes proportionate controls based on deployment criticality: telemetry inventories, local processing, access and retention limits, component and contractor assurance, controlled maintenance, recall-specific chain of custody, and verified sanitization. These controls extend critical-infrastructure protection from network security to the full service and hardware lifecycle.

Keywords: critical infrastructure; battery telemetry; micromobility; supply-chain risk; data minimization; lifecycle security

1. Introduction

In July 2026, shared electric scooters and assisted bicycles were introduced at the Ichigaya headquarters of Japan's Ministry of Defense. When concerns were raised about location data, the defense minister stated that location data alone were not expected to create an information-security problem [1]. The statement is useful as a policy vignette because it captures a common assessment boundary: if a device's coordinates are not classified and an individual trip appears innocuous, the service may seem operationally convenient and security-neutral. That boundary is too narrow for devices used in or around critical infrastructure.

Critical-infrastructure protection concerns systems whose disruption or exploitation could affect national security, public safety, economic activity, or continuity of essential services. Transportation, government facilities, the defense industrial base, commercial facilities, and information technology are recognized sectors [2]. Across those sectors, organizations increasingly rely on equipment delivered as a service: shared vehicles, leased sensors, smart lockers, wearables, inspection devices, delivery robots, charging systems, and other connected assets. The user organization may determine where the equipment is placed while another entity owns the hardware, administers software, stores telemetry, dispatches maintenance, and controls end-of-life handling.

This article calls that class serviced telemetry-emitting hardware: a physical device that records operational data and is used by an organization that does not exercise complete control over its components, software, maintenance, data backend, or disposition. The definition does not imply that the equipment is malicious or that the service provider has acted improperly. It identifies a governance condition: operational dependence exists without end-to-end visibility.

The central argument is that critical-infrastructure assessments should treat telemetry, custody, and provenance as a single lifecycle problem. Location is only one signal. Battery consumption, charging intervals, cycle counts, temperature excursions, odometry, torque, fault logs, and maintenance records can reveal recurring use even when Global Positioning System (GPS) data are unavailable. Exposure can occur immediately through a service backend or later when a device is inspected, returned, recalled, resold, or recycled. Network isolation therefore reduces only part of the attack surface.

The article makes four contributions. First, it translates evidence from mobility privacy and battery side-channel research into a critical-infrastructure threat model. Second, it distinguishes demonstrated capabilities from plausible transfers, avoiding the claim that every battery or service stores the same data. Third, it introduces a lifecycle exposure model spanning acquisition through disposition. Fourth, it provides a control matrix that turns broad calls for trusted supply chains into procurement clauses and verifiable evidence.

2. Scope and structured synthesis method

This is a conceptual policy analysis supported by a structured evidence synthesis, not a systematic review and not a forensic investigation of a specific deployment. Evidence was organized around four questions: (1) whether mobility traces can be linked to individuals or sensitive activities; (2) whether non-positional electrical or battery data can reveal behavior; (3) whether devices retain data that remain accessible through service and end-of-life transitions; and (4) which established supply-chain and device-lifecycle controls can reduce the resulting risk.

The evidence base includes peer-reviewed measurement studies, standards and regulatory documents, official guidance, and well-documented public incidents. The Open Mobility Foundation's privacy guidance is included because it explicitly recognizes that vehicle and trip data remain sensitive even when rider names, contact details, and payment information are absent [3]. Peer-reviewed evidence was prioritized for technical capabilities; government and standards documents were used for control design. News reporting appears only to establish the Japanese policy vignette and the earlier public fitness-tracker incidents.

Transfer from one device class to another was accepted only when the underlying mechanism was shared. For example, a smart-meter study does not prove that a scooter battery identifies a rider. It establishes the more limited proposition that electrical load signatures can encode behavior. Direct evidence from electric-vehicle battery consumption then supports the stronger inference that battery patterns can disclose driver and trip attributes. Each transfer is therefore labelled as demonstrated, supported by analogy, or conditional in Table 1.

The analysis excludes offensive exploitation techniques, firmware reverse engineering, and claims about undisclosed vendor architecture. It also does not treat foreign manufacture as a vulnerability by itself. Risk arises from the combination of data sensitivity, access, retention, custody, legal jurisdiction, and insufficient assurance. The relevant question is not where a supplier is located, but whether the operator can demonstrate who can access the device and its data throughout the lifecycle.

The unit of analysis is the device-service arrangement rather than the device in isolation. That arrangement includes the physical assembly, embedded controllers, batteries, user and technician applications, operator and manufacturer backends, diagnostic tools, subcontractors, warranty processes, and disposition channels. A technically hardened device can still create exposure if a maintenance workflow exports its logs, while a highly connected device can be acceptable when telemetry is strictly minimized, processed locally, and separated from sensitive operational context. This unit prevents the analysis from equating connectivity with risk.

Evidence was evaluated along three dimensions. Technical relevance asks whether a source demonstrates generation, linkage, retention, or access to a signal. Contextual relevance asks whether that mechanism could operate

in a serviced-hardware setting without assuming undisclosed capabilities. Control relevance asks whether a mitigation can be written as a requirement and verified through an artifact or test. Claims supported only by analogy are not used to assert prevalence. This approach favors a bounded chain from evidence to mechanism to control over an exhaustive catalogue of possible threats.

3. Mobility data as critical-infrastructure information

Mobility traces are unusually identifying. A large-scale study of mobile-phone records showed that four spatiotemporal points were sufficient to uniquely characterize 95% of individuals in the studied dataset [4]. Shared-micromobility data create a similar linkage opportunity because vehicle identifiers, timestamps, and origins or destinations can be combined with work schedules, access records, public photographs, or other datasets.

A long-term real-world analysis of shared micromobility found that privacy leakage persisted despite changes in vehicle identifiers and reported that journeys could be reconstructed across time [5]. Earlier scholarship identified the invisible privacy costs of rental scooters [6], while security research described threats arising from positioning, wireless interfaces, user applications, and operator infrastructure [7]. These studies do not establish a compromise at a government facility. They show that apparently impersonal fleet data can preserve continuity and support inference.

The critical-infrastructure consequence is aggregation. A single trip rarely matters. Repeated observations may disclose shift changes, maintenance windows, abnormal staffing, visits to restricted areas, or the difference between routine and surge operations. Data from an externally operated convenience service can become an indirect sensor of the host organization's tempo. This remains true when the service is legitimate and the provider's primary purpose is transportation.

Public fitness-tracker incidents demonstrate how aggregation can expose sensitive populations. In 2018, a global heatmap published by Strava revealed activity around military sites [8]. The United States Department of Defense subsequently restricted geolocation-capable devices, applications, and services in designated operational areas [9]. A separate investigation of Polar fitness data linked activity traces to homes and identities of military and intelligence personnel [10]. The policy lesson is broader than wearable devices: anonymization and absence of classified content do not prevent inference when repeated observations can be joined with external information.

For shared or leased devices, the organization must therefore ask which entities receive raw or derived data, how persistent identifiers are generated, what retention periods apply, whether data are reused for safety or analytics, and whether aggregate outputs can be queried at a granularity that exposes operational patterns. A privacy notice directed at individual consumers does not substitute for a critical-infrastructure data-flow assessment.

Operational sensitivity can also differ from personal-data sensitivity. A dataset may contain no rider name and still disclose that a facility is entering an unusual operating state. Conversely, a dataset that is useful for safety investigations may be legitimate to collect but require stronger separation, retention, and access governance near a sensitive site. The assessment should therefore record both privacy impact and mission impact. Applying only consumer privacy law may miss aggregate operational harm; applying only classified-information rules may miss unclassified patterns whose value emerges through repeated observation.

4. Beyond GPS: battery and non-positional telemetry

A location-only review can fail even when GPS collection is disabled. Battery and power data are shaped by speed, acceleration, gradient, payload, temperature, route conditions, and driving style. Marchiori and Conti demonstrated side-channel attacks that used electric-vehicle battery consumption to identify drivers and driving

style, estimate the number of occupants, and infer trip endpoints when habitual information was available [11]. Their reported average success across attack objectives was 95.4%. The experiment concerns electric vehicles rather than shared scooters, but it directly establishes that battery consumption is not operationally neutral.

The inference mechanism is consistent with earlier work on electrical load signatures. Smart-meter measurements have been used to infer household activities [12], and privacy research has sought to mask appliance load signatures precisely because power profiles reveal use [13]. These studies support a general proposition: time-varying electrical demand can encode behavior. Device class, sampling frequency, sensor precision, and access determine whether a particular inference is feasible.

Battery-management systems (BMSs) add another layer. State-of-health estimation for second-life batteries relies on historical operating profiles and variables such as capacity, current, voltage, temperature, and cycling [14]. European battery regulation defines a BMS as an electronic device that manages and stores parameters used to determine state of health and expected lifetime; it also requires access to updated state-of-health and lifetime information for relevant battery classes [15]. A 2026 fire-investigation study further demonstrated the forensic use of historical BMS voltage, current, and temperature sequences to reconstruct abuse conditions [16].

These sources do not imply that every micromobility battery stores a continuous trip history. Implementations vary. Some systems retain only counters or fault events; others transmit detailed telemetry to a vehicle controller or cloud service. The defensible claim is conditional: when high-resolution consumption data, timestamped events, or persistent health records are retained, they may reveal operational patterns and remain useful after the immediate ride.

The temporal distinction matters. A device can be offline during use yet disclose information later. A technician may connect diagnostic equipment; a returned battery may be evaluated for warranty or second-life value; or a service backend may receive stored records when connectivity resumes. Disabling live transmission is therefore different from preventing data generation, retention, or delayed extraction.

Battery telemetry can be divided into three practical layers. Instantaneous signals include voltage, current, temperature, power, and state of charge. Accumulated signals include cycle count, energy throughput, distance, maximum and minimum values, and fault counters. Event records capture overcurrent, undervoltage, thermal excursions, impacts, charging faults, or controller resets. Even when the first layer is not retained, the second and third may encode frequency, intensity, and abnormality of use. A procurement questionnaire should distinguish these layers because the phrase "battery status" is too broad to support a security decision.

Derived analytics require equal attention. Predictive maintenance, state-of-health scoring, fraud detection, fleet balancing, and warranty analysis may combine raw telemetry with user accounts, device history, weather, maps, and depot records. The derived score may be less interpretable than the raw data yet preserve sensitive correlations for longer. Model training sets, feature stores, exports to analytics vendors, and support tickets are thus part of the data path. A promise not to sell precise location does not answer whether derived patterns are retained or shared.

For critical-infrastructure operators, the minimum assessment unit should be a telemetry inventory rather than a list of radios. The inventory should identify each generated field, sampling interval, storage location, retention period, recipient, diagnostic interface, export function, and derived analytic. It should cover the vehicle controller, BMS, application, operator backend, maintenance tools, and any battery-passport or warranty system.

5. Lifecycle exposure in serviced hardware

The preceding evidence suggests that the attack surface is organized by lifecycle transitions rather than by a single network boundary. Figure 1 maps six stages: procurement, deployment, operation, maintenance, recall or return, and second life or disposal. At each stage, a different party may gain physical or logical access, and data created at an earlier stage may become visible later.

Lifecycle exposure in serviced telemetry-emitting hardware

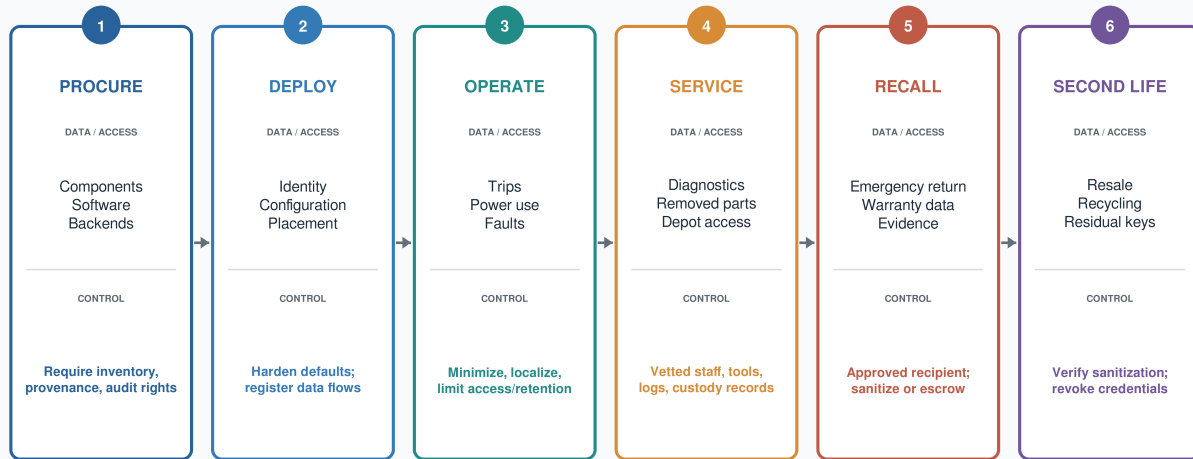


Figure 1. Lifecycle exposure in serviced telemetry-emitting hardware. Information created at one stage may become accessible after a later custody transition; controls therefore span procurement through disposal.

Procurement determines what can be known. Bills of materials, component origin, firmware ownership, cryptographic update mechanisms, diagnostic interfaces, backend sub-processors, and data jurisdictions are difficult to recover after deployment. A contract that specifies only service availability leaves the operator unable to assess telemetry or custody risk. Procurement must therefore require evidence before a device enters a controlled environment.

Deployment establishes identity and context. Device identifiers, ports, geofences, authorized users, and physical placement can link otherwise generic telemetry to a specific facility. Configuration errors can also leave consumer defaults, unnecessary radios, broad permissions, or vendor-wide administrator access in place. A hardened configuration baseline and a record of authorized data flows are required before use.

Operation creates the richest stream: location, time, speed, battery consumption, faults, user-account events, and service analytics. European data-protection guidance for connected vehicles recommends data minimization, local processing where possible, privacy-protective defaults, and controls on third-party transfers [17]. A recent holistic review of electric-vehicle security similarly treats the BMS, charging system, vehicle, and infrastructure as an integrated cyber-physical attack surface [18]. Critical-infrastructure use requires the same integrated view, with operational sensitivity added to personal-data concerns.

Maintenance changes custody. Technicians may attach diagnostic tools, replace controllers, remove batteries, or move equipment off-site. Even when the operational network is isolated, maintenance can bridge the device to a vendor laptop, mobile application, depot network, or warranty portal. Contractor vetting, authorized tools, access logging, tamper evidence, and documented chain of custody are therefore security controls, not administrative details.

Recall or return is a distinct stage because safety can override ordinary disposition plans. Lithium-ion batteries may be returned rapidly after faults, thermal events, or manufacturer notices. A contract that requires sanitization only at scheduled end of life may not cover emergency return. The organization needs a recall protocol that identifies data-bearing components, preserves evidence when required, limits recipients, and documents whether data were deleted, cryptographically erased, retained under legal hold, or transferred with explicit authorization.

Second-life use, refurbishment, resale, and recycling create the final custody transition. Batteries have economic value precisely because their condition can be estimated from use history. Devices may also contain persistent identifiers, credentials, logs, or configuration data. Disposition controls must apply to the whole assembly and to removed components, not only to conventional storage media.

Three threat scenarios illustrate how stages combine. In a backend scenario, a legitimate service continuously aggregates device events and is later compromised, legally compelled, or misconfigured. In a maintenance scenario, a device stores telemetry locally and discloses it only when a contractor connects a diagnostic tool. In a return scenario, an apparently defective battery leaves the site under an urgent safety process and its retained history is examined by parties not covered by the routine data agreement. The same deployment may face all three scenarios, and controls that address only cloud access will not cover the latter two.

Lifecycle risk can be expressed conceptually as the product of informativeness, linkability, accessibility, persistence, and consequence. The formulation is not intended as a quantitative score: evidence is not yet sufficient to assign universal probabilities. It is a review discipline. A low-resolution signal may become important when persistently linked to one site; a highly informative signal may pose limited risk when immediately aggregated and inaccessible; and a routine dataset may become consequential during a crisis. Recording each factor makes the rationale for acceptance, restriction, or rejection auditable.

6. Evidence-to-risk synthesis

Table 1 separates direct demonstrations from conditional transfer. The strongest evidence concerns mobility re-identification and battery-based inference. The lifecycle conclusion is a synthesis: if data can identify activity and if access changes across service transitions, then custody and retention must be governed as part of critical-infrastructure protection. This conclusion does not depend on a malicious manufacturer; ordinary diagnostics, warranty processes, and analytics are sufficient to create access paths.

Table 1. Evidence supporting the serviced-hardware threat model

Evidence domain	Demonstrated capability	Transfer to serviced hardware	Boundary
Human mobility traces	Sparse spatiotemporal points can uniquely characterize individuals [4].	Repeated vehicle events may be joined with schedules or access data.	Direct for mobility data; identity requires auxiliary information.
Shared micromobility	Longitudinal vehicle activity can be reconstructed despite identifier changes [5].	Fleet telemetry can preserve continuity around a facility.	Direct for studied services; architecture differs by operator.
Battery side channels	Electric-vehicle battery consumption revealed driver, style, occupancy, and habitual endpoints [11].	Battery or controller data may expose recurring operational patterns.	Direct for electric-vehicle datasets; conditional on resolution and access.
Electrical load inference	Power signatures can reveal appliance use and behavior [12,13].	Supports inference from non-positional telemetry.	Mechanism analogy; not proof for every device.
BMS history	Health and forensic analysis use cycle, voltage, current, and temperature history [14-16].	Retained records may remain informative during service or return.	Data depth and storage location are implementation-specific.
Lifecycle custody	Supply-chain and IoT guidance treats access, logging, support, and sanitization as lifecycle controls [19-23].	Maintenance, recall, and disposal require explicit assurance.	Normative guidance; effectiveness requires verification.

The synthesis also clarifies what should not be claimed. A battery cycle count alone usually cannot reconstruct a route. A foreign supplier is not automatically an adversary. Whitelisting does not eliminate compromise. The risk becomes material when informative data, persistent linkage, accessible interfaces, weak custody, and consequential deployment occur together. Controls should be proportionate to that combination.

7. A lifecycle assurance framework

Established cybersecurity supply-chain risk management already requires organizations to identify, assess, and mitigate risks arising from products and services across the supply chain [19]. The gap is not the absence of a general principle but its application to small, convenient, externally serviced devices. Such devices may fall below the threshold of traditional capital-equipment review even though their placement and telemetry make them sensitive.

The proposed framework uses five assurance questions. First, what data are generated, derived, stored, and transmitted? Second, who can access the device or data at each lifecycle stage? Third, where do software, components, diagnostic tools, and service backends originate and operate? Fourth, what event changes custody, and what evidence accompanies that change? Fifth, how can the operator verify that contractual controls work in practice?

Table 2 converts those questions into minimum requirements. The controls are evidence-oriented. A statement that data are secure is weaker than a field-level data inventory, retention schedule, sub-processor list, architecture diagram, access log, software bill of materials, signed sanitization record, or right-to-audit report. Procurement should specify the artifact that demonstrates compliance.

Table 2. Lifecycle controls and auditable evidence

Stage	Control objective	Minimum requirement	Evidence of compliance
Procurement	Establish visibility before deployment	Data inventory; component and software provenance; sub-processor and jurisdiction list	Architecture diagram; software bill of materials; supplier attestations; contract schedules
Deployment	Bind device to approved context	Hardened configuration; disabled unnecessary interfaces; approved identifiers and zones	Configuration record; acceptance test; asset registration
Operation	Minimize and contain telemetry	Purpose limitation; local processing where feasible; bounded retention; least privilege	Field-level schema; retention test; access logs; deletion evidence
Maintenance	Control diagnostic and physical access	Vetted staff; authorized tools; logged sessions; chain of custody; tamper evidence	Work order; access log; tool inventory; custody receipt
Recall/return	Prevent emergency return from bypassing security	Data-bearing component check; approved recipient; sanitize, escrow, or controlled retention	Recall playbook; transfer authorization; sanitization or legal-hold record
Second life/disposal	Remove residual data and credentials	Verified sanitization of all components; key revocation; controlled recycler	Sanitization certificate; revocation log; recycler audit
Continuous assurance	Detect changes in supplier or architecture	Incident notice; vulnerability support; material-change approval; periodic reassessment	Update records; support dates; audit report; change notifications

Data minimization should begin at collection. Fields not required for the approved use case should be disabled or aggregated. Local processing is preferable when the service can function without exporting raw telemetry. Persistent identifiers should rotate when continuity is unnecessary, and retention should be bounded by a documented purpose. Derived data, model features, and backups must be included because deleting a raw record while retaining an equally revealing derivative does not reduce exposure.

Device capabilities must support the policy. Guidance from the U.S. National Institute of Standards and Technology (NIST) for Internet of Things devices identifies secure data storage, audit-event generation, log

retention, and the ability to sanitize or purge data as relevant capabilities [20]. These requirements should be tested before purchase. If a device cannot enumerate or erase retained data, the operator cannot reliably govern maintenance, return, or disposal.

Sanitization should be defined by outcome rather than a generic factory reset. Current NIST media-sanitization guidance distinguishes methods according to media and confidentiality risk [21]. For integrated devices, the process should identify every data-bearing component, verify the result, record the person and tool used, and address keys or credentials that enable access to remote records. Where sanitization would destroy safety evidence, controlled retention and transfer may be more appropriate than deletion; the decision should be explicit.

Supplier assurance should be risk-based. For high-consequence sites, requirements may include component provenance, signed firmware, controlled update infrastructure, named service locations, screened personnel, domestic or otherwise approved data hosting, and independent testing. For ordinary civilian fleets, transparency, minimization, access controls, and verified deletion may be sufficient. A tiered approach avoids treating all deployments as classified while preventing convenience services from bypassing review entirely.

A three-tier profile is sufficient for many organizations. Tier 1 covers ordinary public settings and emphasizes transparency, access control, reasonable retention, supported software, and verified deletion. Tier 2 covers facilities where aggregate activity could affect continuity or security and adds local or regional processing, restricted identifiers, approved maintenance, material-change notification, and recall exercises. Tier 3 covers mission-sensitive zones and may require dedicated fleets, offline or one-way operation, organization-controlled keys, approved-source components, independent testing, escorted maintenance, and prohibition of off-site return before sanitization or controlled evidence transfer.

Contracts should allocate responsibility when controls fail. Required terms include incident-notification time, vulnerability disclosure and remediation, subcontractor flow-down, support and end-of-life dates, audit access, return or destruction of data, restrictions on secondary use and model training, government or customer access to relevant logs, and consequences for unapproved architectural change. A supplier should also disclose when safety or legal obligations prevent deletion. The objective is not to demand impossible guarantees but to prevent ambiguity from surfacing only after an incident or recall.

8. Interorganizational and cross-sector dependencies

Serviced hardware often crosses organizational boundaries. A transportation service may operate at a government facility, use commercial cellular networks, depend on cloud infrastructure, and send batteries to an external depot. Each participant may satisfy its own sector-specific obligations while the end-to-end data and custody path remains unowned. This is a classic critical-infrastructure dependency problem: local controls do not guarantee system-level assurance.

Inconsistent procurement rules create a weakest-link effect. An organization may restrict personal devices yet admit functionally similar sensors through a facilities or mobility contract. One site may require local storage while another permits the same fleet to use a global backend, allowing patterns to be inferred across a shared workforce or joint operation. Harmonized minimum requirements are therefore valuable across agencies, operators, and allied or partner organizations.

Regulatory precedent supports anticipatory supply-chain controls. The United States connected-vehicle rule addresses national-security risks associated with covered connectivity hardware and software linked to specified foreign adversaries [22]. The rule is narrower than the framework proposed here, but it demonstrates that governments need not wait for a documented individual compromise before imposing provenance and jurisdictional

requirements on connected transportation technology.

The broader policy should remain vendor-neutral and capability-based. Jurisdiction is one factor because it shapes legal access and government compulsion, but technical architecture and operational practice matter as well. A domestic service with excessive retention and uncontrolled contractors may present more risk than a foreign-origin component operated under transparent, locally controlled conditions. The framework therefore uses approved-source lists only as one layer within continuous assurance.

Governance ownership must be explicit. Facilities teams may own physical placement, procurement teams the contract, cybersecurity teams the network, privacy teams personal information, and safety teams recalls. None may own the combined lifecycle. Designating an accountable service owner and a cross-functional approval path prevents gaps between these domains. The owner should maintain the authoritative data and custody model and have the power to suspend deployment when a supplier, component, backend, or support process changes materially.

9. Implementation priorities

Organizations can begin without creating a new bureaucracy. The first priority is to add serviced telemetry-emitting hardware to existing asset and supply-chain inventories. The second is to require a data-flow and custody worksheet during procurement. The third is to define prohibited deployment zones and higher assurance tiers. The fourth is to create maintenance, recall, and disposition procedures that are exercised rather than left as contract language.

A practical pilot can examine one existing service. The operator should enumerate device and backend data, observe diagnostic and maintenance workflows, test account and identifier separation, verify retention and deletion, inspect sub-processor and hosting arrangements, and conduct a mock emergency recall. Findings can be mapped to Table 2 and used to revise the contract or restrict deployment. This produces evidence without requiring access to proprietary algorithms.

Lifecycle support should be planned before purchase. NIST's 2026 guidance for Internet of Things product manufacturers emphasizes cybersecurity support through the product lifecycle and end of life [23]. Critical-infrastructure customers should request the corresponding support period, vulnerability process, update mechanism, end-of-life notice, and data-handling plan. A service should not remain in a sensitive setting after the provider can no longer support its software or components.

Metrics should track assurance rather than incident counts alone. Useful measures include the percentage of devices with complete telemetry inventories, percentage of service providers with named sub-processors, median time to revoke maintenance access, percentage of returned components with verified sanitization, and number of emergency-return exercises completed. An absence of known leaks is not evidence that lifecycle controls are effective.

Exercises should include non-cyber triggers. A thermal fault, bankruptcy, contract termination, software end of support, law-enforcement request, or sudden geopolitical restriction can force a custody or service change. The organization should test whether it can locate all deployed units and spare batteries, disable accounts and credentials, preserve necessary safety evidence, prevent unauthorized return, and continue the underlying service. This links confidentiality controls to resilience: a lifecycle plan is effective only if the essential function can continue while risky equipment is isolated or replaced.

10. Limitations and research agenda

This article has four principal limitations. First, the Japanese case is used only as a public policy vignette. The analysis has no access to the service architecture, contract, vehicle configuration, or security review, and it does not allege that sensitive information was exposed. Second, battery implementations vary widely; the presence, resolution, retention, and accessibility of historical data must be established device by device.

Third, the evidence synthesis is structured but not systematic. It was designed to connect established mechanisms to lifecycle controls, not to estimate prevalence or effect size. Fourth, stronger controls impose cost and may reduce service convenience. The proposed tiers require validation through procurement pilots and comparative risk assessment.

Future work should measure which telemetry fields are retained in shared micromobility controllers and batteries, how reliably operational attributes can be inferred at realistic sampling rates, and what data remain after maintenance and factory-reset procedures. Red-team exercises should test delayed extraction during service and recall without developing or publishing techniques that would facilitate unauthorized access.

Policy research should compare procurement clauses across transportation, government, energy, and health infrastructure; evaluate whether battery-passport regimes create new access-control requirements; and quantify the cost of chain-of-custody controls. A shared assurance profile for serviced hardware would help small operators apply protections that are currently available mainly to large security organizations.

11. Conclusion

Critical-infrastructure organizations increasingly depend on devices whose ownership, maintenance, data backend, and disposition remain outside their direct control. Treating such equipment as a network endpoint or a location-privacy question misses the lifecycle. Mobility traces can re-identify; battery consumption can reveal behavior; BMS and service records can preserve history; and maintenance, recall, and second-life transitions can move data-bearing components into new hands.

The appropriate response is not a categorical ban on shared mobility or connected equipment. It is proportionate assurance: know what the device records, know who can access it, control each custody transition, and require evidence that minimization, retention, access, update, and sanitization controls work. Extending supply-chain risk management to small serviced devices closes a gap between cybersecurity policy and the physical lifecycle of modern infrastructure.

Declarations

Competing interests: The author declares no competing interests.

Funding: This work received no specific grant from any funding agency.

Ethics approval and consent to participate: Not applicable. The article uses published and publicly available sources and reports no human-participant research.

Consent for publication: Not applicable.

Data availability: No new dataset was generated. All sources used in the synthesis are identified in the reference list.

Author contribution: The sole author: Conceptualization, investigation, methodology, writing—original draft, and writing—review and editing.

Declaration of generative artificial intelligence (AI) in scientific writing: Generative AI was used to assist language editing, document formatting, and consistency checks. The author reviewed and takes responsibility for the

manuscript's content, claims, and references.

References

- [1] H. Umebayashi, Defense minister comments on LUUP introduction: "No information-security problem" [in Japanese], ITmedia NEWS, 3 July 2026. <https://www.itmedia.co.jp/news/articles/2607/03/news128.html> (accessed 10 July 2026).
- [2] Cybersecurity and Infrastructure Security Agency, Critical Infrastructure Sectors, 2026. <https://www.cisa.gov/topics/critical-infrastructure-security-and-resilience/critical-infrastructure-sectors> (accessed 10 July 2026).
- [3] Open Mobility Foundation, MDS Privacy Guide for Cities, 2020. <https://www.openmobilityfoundation.org/introducing-the-mds-privacy-guide-for-cities/> (accessed 10 July 2026).
- [4] Y.-A. de Montjoye, C.A. Hidalgo, M. Verleysen, V.D. Blondel, Unique in the crowd: The privacy bounds of human mobility, *Scientific Reports* 3 (2013) 1376. <https://doi.org/10.1038/srep01376>.
- [5] K. Elzer, E. Jedermann, S. Roos, J. Schmitt, They see me scooting—A long-term real-world data analysis of shared micro-mobility services and their privacy leakage, in: 2025 IEEE 10th European Symposium on Security and Privacy, 2025, pp. 78–92. <https://doi.org/10.1109/EuroSP63326.2025.00014>.
- [6] A.B. Petersen, Scoot over smart devices: The invisible costs of rental scooters, *Surveillance & Society* 17 (2019) 191–197. <https://doi.org/10.24908/ss.v17i1/2.13112>.
- [7] N. Vinayaga-Sureshkanth, R. Wijewickrama, A. Maiti, M. Jadliwala, Security and privacy challenges in upcoming intelligent urban micromobility transportation systems, in: *Proceedings of the Second ACM Workshop on Automotive and Aerial Vehicle Security*, 2020, pp. 31–35. <https://doi.org/10.1145/3375706.3380559>.
- [8] A. Hern, Fitness tracking app Strava gives away location of secret US army bases, *The Guardian*, 28 January 2018. <https://www.theguardian.com/world/2018/jan/28/fitness-tracking-app-gives-away-location-of-secret-us-army-bases> (accessed 10 July 2026).
- [9] U.S. Department of Defense, Use of Geolocation-Capable Devices, Applications, and Services, Memorandum, 3 August 2018. <https://www.defense.gov/News/Releases/Release/Article/1594486/department-of-defense-issues-guidance-on-use-of-geolocation-capabilities/> (accessed 10 July 2026).
- [10] F. Postma, After Strava, Polar is revealing the homes of soldiers and spies, *Bellingcat*, 8 July 2018. <https://www.bellingcat.com/resources/articles/2018/07/08/strava-polar-revealing-homes-soldiers-spies/> (accessed 10 July 2026).
- [11] F. Marchiori, M. Conti, Leaky batteries: A novel set of side-channel attacks on electric vehicles, in: *Computer Security—ESORICS 2025, Lecture Notes in Computer Science*, 2025, pp. 322–333. https://doi.org/10.1007/978-3-032-00624-0_16.
- [12] A. Molina-Markham, P. Shenoy, K. Fu, E. Cecchet, D. Irwin, Private memoirs of a smart meter, in: *Proceedings of the 2nd ACM Workshop on Embedded Sensing Systems for Energy-Efficiency in Building*, 2010, pp. 61–66. <https://doi.org/10.1145/1878431.1878446>.
- [13] G. Kalogridis, C. Efthymiou, S.Z. Denic, T.A. Lewis, R. Cepeda, Privacy for smart meters: Towards undetectable appliance load signatures, in: *2010 First IEEE International Conference on Smart Grid Communications*, 2010, pp. 232–237. <https://doi.org/10.1109/SMARTGRID.2010.5622047>.
- [14] E. Braco, I. San Martín, P. Sanchis, A. Ursúa, D.-I. Stroe, State of health estimation of second-life lithium-ion batteries under real profile operation, *Applied Energy* 326 (2022) 119992. <https://doi.org/10.1016/j.apenergy.2022.119992>.
- [15] European Parliament and Council, Regulation (EU) 2023/1542 of 12 July 2023 concerning batteries and waste batteries, *Official Journal of the European Union* L 191 (2023) 1–117.
- [16] L. Liu, Y.A. Wu, H. Zhen, Fire investigation based on time-sequential analysis of lithium-ion battery thermal runaway, *Fire* 9 (2026) 211. <https://doi.org/10.3390/fire9050211>.
- [17] European Data Protection Board, Guidelines 01/2020 on processing personal data in the context of connected vehicles and mobility related applications, Version 2.0, 9 March 2021. https://www.edpb.europa.eu/documents/guideline/guidelines-012020-on-processing-personal-data-in-the-context-of-connected_en (accessed 10 July 2026).

- [18] A. Brighente, M. Conti, D. Donadel, R. Poovendran, F. Turrin, J. Zhou, Electric vehicles security and privacy: Challenges, solutions, and future needs, *ACM Transactions on Cyber-Physical Systems* 10(3) (2026) 1–27. <https://doi.org/10.1145/3801968>.
- [19] National Institute of Standards and Technology, Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations, NIST SP 800-161 Rev. 1 Update 1, 2024. <https://doi.org/10.6028/NIST.SP.800-161r1-upd1>.
- [20] National Institute of Standards and Technology, IoT Device Cybersecurity Guidance for the Federal Government: IoT Device Cybersecurity Requirement Catalog, NIST SP 800-213A, 2021. <https://doi.org/10.6028/NIST.SP.800-213A>.
- [21] R. Chandramouli, E. Hibbard, Guidelines for Media Sanitization, NIST SP 800-88 Rev. 2, 2025. <https://doi.org/10.6028/NIST.SP.800-88r2>.
- [22] U.S. Department of Commerce, Bureau of Industry and Security, Securing the Information and Communications Technology and Services Supply Chain: Connected Vehicles, Final Rule, 90 Federal Register 5360, 16 January 2025. <https://www.govinfo.gov/content/pkg/FR-2025-01-16/html/2025-00592.htm> (accessed 10 July 2026).
- [23] National Institute of Standards and Technology, Foundational Cybersecurity Activities for IoT Product Manufacturers, NIST IR 8259 Rev. 1, 2026. <https://doi.org/10.6028/NIST.IR.8259r1>.